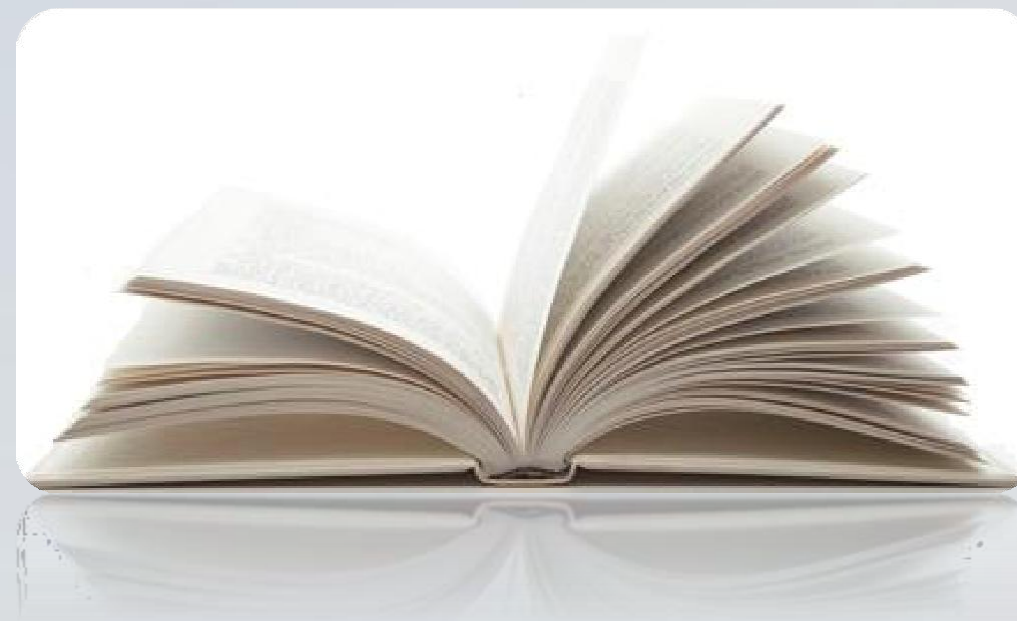


BLOQUE 2: PROTECCIÓN DE DATOS - RGPD



- ❖ 2.1 Marco normativo nacional e internacional.
- ❖ 2.2 Roles del CISO y el DPO
- ❖ 2.3 De donde venimos y dónde estamos
- ❖ 2.4 EL RGPD y la LOPDGDD. Principios
- ❖ 2.5 Garantía de los Derechos Digitales



2.1 MARCO NORMATIVO NACIONAL E INTERNACIONAL

- El Reglamento General de Protección de Datos (GDPR) se creó para agrupar en una normativa comunitaria que simplificara el cumplimiento simultáneo de múltiples regulaciones locales y unificara la legislación, normativa y procesos de protección de datos en la UE.
- Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo de 27 de abril de 2016, es relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos (Reglamento general de protección de datos o RGPD en lo sucesivo) y por el que se deroga la Directiva 95/46/CE.
- Ley Orgánica 3/2018, de 5 de diciembre, de protección de datos personales y garantía de los derechos digitales



EL CISO MIEMBRO PERMANENTE EN COMITÉS DE SEGURIDAD

• Protección de datos

- ☐ El CISO debe liderar diferentes órganos de gestión como el comité de seguridad de la información o el comité de ciberseguridad.
- ☐ Debe ser parte relevante en el caso del comité de protección de datos, dónde materialice su misión principal de gestión e implantación de la estrategia de seguridad de la información corporativa.
- ☐ Cada área de la empresa, debe asumir su propia parte de seguridad, y el CISO generará una cultura de seguridad en la organización con relación a la normativa de protección de datos personales.



ACTIVIDADES Y RESPONSABILIDADES DEL CISO EN RGPD

• Protección de datos

- ☐ **PROTEGER:** Supervisar (al menos) la seguridad y privacidad de los datos según las funciones que se hayan establecido de manera complementaria al Delegado De Protección de Datos.
- ☐ **INFORMAR Y COORDINARSE:** Coordinarse con otras figuras relevantes relacionadas con su ámbito de actuación tales como Protección de Datos, Área Jurídica, Auditoría, Riesgos Corporativos, Comunicación, Recursos Humanos.



2.2 ROLES DEL CISO

• Protección de datos



❑ Roles del CISO: SEGURIDAD DE LA INFORMACIÓN

- Generar e implantar políticas de seguridad de la información
- Garantizar la seguridad y privacidad de los datos.
- Supervisar la administración del control de acceso a la información.
- Supervisar el cumplimiento normativo de la seguridad de la información.
- Responsable del equipo de respuesta ante incidentes de seguridad de la información de la organización.
- Supervisar la arquitectura de seguridad de la información de la empresa.

2.2 ROLES DEL DPO

• Protección de datos



▣ Roles del DPO: PRIVACIDAD

- Informar y asesorar al responsable o al encargado del tratamiento y a los empleados que se ocupen del tratamiento de las obligaciones que les incumben en virtud del RGPD.
- Supervisar el cumplimiento de lo dispuesto en el RGPD y de las políticas en materia de protección de datos del Responsable.
- Concienciación y formación del personal que participe en las operaciones de tratamiento y las auditorías correspondientes.
- Asesoramiento que se le solicite acerca de la evaluación de impacto relativa a la protección de datos y supervisar su aplicación
- Cooperar con la autoridad de control ante las notificaciones de violaciones de seguridad

2.3 DE DÓNDE VENIMOS Y DÓNDE ESTAMOS

LOPD

Consentimiento tácito

3 niveles: alto, medio y básico

Inscripción pública de ficheros

Responsable de Seguridad

Medidas de seguridad establecidas en RD

Seguridad reactiva

Derechos: ARCO

RGPD

Consentimiento expreso

2 niveles: especiales y no especiales

Registro interno de actividades de tratamiento

Delegado de Protección de Datos

Medidas de seguridad definidas por la entidad

Seguridad proactiva y preventiva: Vigilancia

Derechos: ARCO + olvido + portabilidad +
limitación

2.4 EL RGPD y la LOPDGDD. Principios

2.4.1 Principios del RGPD

- **Los principios de la protección de datos deben aplicarse a toda la información relativa a una persona física identificada o identificable.**
- Los datos personales deben ser tratados de forma lícita, leal y transparente.
- Los datos personales deben ser recogidos con fines determinados explícitos y legítimos.
- Los datos personales deben ser adecuados, pertinentes y limitados a lo necesario en relación con el tratamiento.
- Los datos personales deben ser exactos y estar siempre actualizados.
- Los datos personales deben mantenerse de forma que se permita la identificación de los interesados durante no más tiempo del necesario para los fines del tratamiento.
- Los datos personales deben ser tratados de tal manera que se garantice su seguridad



2.4.2 DERECHOS DEL INTERESADO

- **Garantizar la protección de los datos personales de los interesados, es uno de los objetivos principales del RGPD y LOPDGDD.**
- **Derecho de información:** el interesado ha de ser informado de que datos personales están siendo tratados, de quien el responsable del tratamiento, de las finalidades del tratamiento, la legitimación del tratamiento, de las cesiones, periodos de conservación, derechos reconocidos y como solicitarlos.
- **Transparencia:** Tanto el deber de información como las respuestas a los ejercicios de derechos, ésta se debe proporcionar de forma concisa, transparente, inteligible y de fácil acceso, con un lenguaje claro y sencillo.
- **Clausulas informativas:** Evitar acudir a fórmulas especialmente farragosas y que incorporen remisiones a los textos legales. Deben de explicar el contenido al que inmediatamente nos referiremos de una forma clara y accesible para los interesados, con independencia de sus conocimientos en la materia.



2.4.3 RESPONSABLE DEL TRATAMIENTO Y ENCARGADO DEL TRATAMIENTO

• Obligaciones Generales.

- **Responsable del Tratamiento:** persona física o jurídica, autoridad pública, agencia u otro ente que, solo o en conjunto con otros, determina los propósitos y medios del procesamiento de datos personales.
- **Encargado del Tratamiento:** es la persona física o jurídica, autoridad pública, agencia u otro ente que procesa datos personales en nombre del responsable.
- **Corresponsable del Tratamiento:** cuando, junto con una o más organizaciones, determine conjuntamente «por qué» y «cómo» deberán tratarse los datos personales.
- **Responsabilidades del Responsable:** debe ser capaz de demostrar el cumplir con los principios relacionados con el tratamiento de datos personales, y debe implementar medidas técnicas y organizativas apropiadas para asegurar y ser capaz de demostrar que el tratamiento se hace de acuerdo con esta regulación.
- **Responsabilidades del Encargado:** el tratamiento realizado en nombre de un responsable, éste debe usar solo encargados que ofrezcan suficientes garantías para implementar las medidas técnicas y organizativas apropiadas, de manera tal que el tratamiento cumpla los requerimientos de esta regulación y asegure la protección de los derechos de los interesados. Queda regulado de forma escrita en un contrato de prestación de servicios.



2.4 DOCUMENTOS Y REGISTROS RGPD

- **Conceptos de protección de datos desde el diseño y protección de datos por defecto.**

- **Protección de datos desde el diseño y por defecto:** implica que el responsable aplicará, tanto en el momento de determinar los medios de tratamiento como en el momento del tratamiento mismo, las medidas técnicas y organizativas adecuadas (como por ejemplo la seudonimización) concebidas para aplicar de manera efectiva los principios de protección de datos, e integrar las garantías necesarias en el tratamiento, para cumplir los requerimientos del Reglamento
- **Asimismo**, el responsable aplicará las medidas técnicas y organizativas adecuadas para garantizar que, por defecto, sólo se traten los datos personales necesarios para cada finalidad específica del tratamiento.



2.4 DOCUMENTOS Y REGISTROS RGPD

- **El RGPD prevé nuevas obligaciones de documentación del tratamiento para los responsables o los encargados del tratamiento.**
- **Registro de actividades de Tratamiento:** registro de las actividades de tratamiento efectuadas bajo su responsabilidad. Este registro deberá de contener, respecto de cada actividad, la información establecida en el Artículo 30 del RGPD:
 - Datos de contacto del Responsable y, en su caso, del DPO si existiese.
 - Finalidades del Tratamiento
 - Descripción de categorías de los interesados y categoría de los datos personales.
 - Destinatarios a quienes se comunican
 - Transferencias internacionales de datos, en su caso.
 - Plazos de conservación (cuando sea posible).
 - Descripción de medidas técnicas y organizativas, para garantizar un nivel de seguridad adecuado al riesgo



2.4 DOCUMENTOS Y REGISTROS RGPD

• Seguridad de los datos personales.

- **Seguridad del tratamiento:** Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.
- **Algunas de las medidas técnicas y organizativas :**
 - la seudonimización y el cifrado de datos personales.
 - la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento.
 - la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida, en caso de incidente físico o técnico
 - un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento



2.4 DOCUMENTOS Y REGISTROS RGPD

•Evaluaciones de Impacto

- **Evaluación de Impacto:** Cuando un tratamiento, en particular si utiliza nuevas tecnologías, por su naturaleza, alcance, contexto o fines, entrañe un alto riesgo para **los derechos y libertades de las personas físicas**, el responsable del tratamiento realizará, antes del tratamiento, una evaluación del impacto en la protección de datos personales (EIPD).
- **Deberá de realizarse cuando:**
 - En base a los datos se generen perfiles sobre cuya base se tomen decisiones que produzcan efectos jurídicos.
 - Cuando se haga tratamientos a gran escala de datos sensibles.
 - Cuando exista observación sistemática a gran escala de una zona de acceso público.
- **La AEPD publico** un listado de aquellos tratamientos que **SI** deben de realizar una EIPD. Algunos ejemplos: Tratamientos de datos biométricos y genéticos, tratamientos perfilados o valoración de sujetos, tratamientos de impliquen toma de decisiones automatizadas. <https://www.aepd.es/media/criterios/listas-dpia-es-35-4.pdf>
- **Gestiona EIPD:** Asistente para el análisis de riesgos y evaluaciones de impacto en protección de datos. Esta herramienta gratuita de la AEPD, guía a los responsables y encargados del tratamiento en los aspectos que se deben tener en cuenta, proporcionando una base inicial para una gestión adecuada: <https://gestiona.aepd.es/>

2.4 DOCUMENTOS Y REGISTROS RGPD

- **Análisis de Riesgos (principios de responsabilidad proactiva.)**
- Conjunto de actividades y tareas que incluyen la identificación y evaluación del riesgo, así como, las medidas para su reducción o mitigación
 - **Puede llevarse a cabo** utilizando alguna de las metodologías o estándares de análisis de riesgo existentes: MAGERIT, ISO, etc.
 - **Un análisis de riesgos** requiere identificar las amenazas (por ejemplo, acceso no autorizado a los datos personales), valorar cuál es la probabilidad de que se produzca y el impacto que tendría en las personas afectadas.

• ANÁLISIS DE RIESGOS:

- **Identificar las amenazas:** cualquier factor riesgo con potencial para provocar daño perjuicio a los interesados: Acceso Ilegítimo (confidencialidad), Modificación no autorizada (integridad), Eliminación de los datos (disponibilidad)
- **Evaluar los Riesgos:** implica considerar todos los posibles escenarios en los cuales el riesgo se haría efectivo.
- **Tratar los riesgos:** disminuir su nivel de exposición con medidas de control.

2.4 DOCUMENTOS Y REGISTROS RGPD

•Violaciones de Seguridad

•Se entiende por brecha de seguridad o violación de la seguridad de los datos personales todo aquel incidente de seguridad que provoque la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizado a dichos datos. Si se produce una violación de la seguridad, el responsable debe notificarlo a la Autoridad de Control sin dilación indebida y, si es posible, en un plazo máximo de 72 horas desde que tenga constancia.

- **Se debe de incluir:** descripción de tallada de la violación de seguridad, posibles consecuencias sobre los datos, medidas adoptadas tras el incidente.
- **Comunicar al interesado:** cuando entrañe un alto riesgo para los derechos y libertades de las personas físicas (salvo cuando suponga un esfuerzo desproporcionado)
- **Canal de notificación de la AEPD:** <https://sedeagpd.gob.es/sede-electronica-web/>
- **Cuando no se ha de comunicar la violación:** cuando no sea improbable que constituya un riesgo para los derechos y las libertades de las personas.
 - El responsable haya adoptado medidas de protección adecuadas, como que los datos no sean inteligibles para personas no autorizadas
 - El responsable haya aplicado medidas posteriores a que garanticen que ya no sea probable que se concrete el alto riesgo.

2.4 DOCUMENTOS Y REGISTROS RGPD

•Transferencias Internacionales de datos (TID)

- Las transferencias internacionales de datos suponen un flujo de datos personales desde el territorio español a destinatarios establecidos en países fuera del Espacio Económico Europeo (es decir, fuera de los países de la Unión Europea, más Liechtenstein, Islandia y Noruega).
- De acuerdo con el RGPD, los datos sólo podrán ser comunicados fuera del Espacio Económico Europeo en los siguiente casos:
 - A países, territorios o sectores específicos (el RGPD también incluye organizaciones internacionales) sobre los que la Comisión haya adoptado una decisión reconociendo que ofrecen un nivel de protección adecuado.
 - Cuando se han ofrecido garantías adecuadas sobre la protección que los datos recibirán en su destino (Privacy Shield).
 - Cuando se aplique alguna de las excepciones que permiten transferir los datos sin garantías de protección adecuada por razones de necesidad vinculadas al propio interés del titular de los datos o a intereses generales.



2.5 GARANTÍA DE LOS DERECHOS DIGITALES (LOPDGDD)

- **Se introduce en la nueva LOPD GDD, la garantía de los derechos digitales.**
- El término derechos digitales alude a los permisos de las personas para realizar acciones legítimas que comprenden el uso de: un ordenador, todo tipo de dispositivos electrónicos, una red de comunicaciones.
- Son varios los derechos que corresponden a los ciudadanos en el mundo digital y diferentes las clasificaciones que de ellos se han hecho. Todos ellos están relacionados con la privacidad e igualdad en Internet, la supresión de nuestros datos en la red y la protección de los menores. Por Sectores:
 - **Trabajadores:** Derecho a la desconexión digital, a la intimidad en el uso de las cámaras y sistemas de geolocalización.
 - **Menores:** Consentimiento para tratar sus datos, derecho a la educación digital.
 - **Derechos en Internet:** Olvido, Bono social, Neutralidad de Internet, Testamento Digital, Libertad de expresión y veracidad informativa, Derecho al honor y la propia imagen, propiedad intelectual.



2.5 GARANTÍA DE LOS DERECHOS DIGITALES (LOPDGDD)

- **Se introduce en la nueva LOPD, la garantía de los derechos digitales.**
- Existen principalmente dos derechos de los trabajadores en el ámbito digital
- **Desconexión digital:** los empleados, tendrán derecho a estar desconectados digitalmente fuera de su jornada laboral. Tiene la finalidad de garantizar el respeto de su tiempo de descanso, vacaciones así como su intimidad personal y familiar.
- **Derecho a la intimidad en el uso de cámaras o sistemas de geolocalización:** derecho a la intimidad en el ámbito laboral frente al uso de dispositivos de geolocalización, videovigilancia grabación de sonido. Se prohíbe de forma expresa el uso de estos dispositivos en lugares como vestuarios, aseos o comedores.
 - El uso de esos sistemas sólo se admitirá por parte de la empresa cuando haya un riesgo relevante para la seguridad de las instalaciones, bienes y personas, y siempre previa información a los trabajadores.
- **Igualmente**, se garantiza la privacidad del Empleado, cuando el empresario acceda al contenido de los dispositivos para control de cumplimiento de funciones y obligaciones, y garantizar la integridad de los dispositivos.

2.5 GARANTÍA DE LOS DERECHOS DIGITALES (LOPDGDD)

• **Se introduce en la nueva LOPD, la garantía de los derechos digitales.**

• **LOPDGDD 3/2018 ha introducido un nuevo art. 20 bis en el Estatuto de los Trabajadores:** Derechos de los trabajadores a la intimidad en relación con el entorno digital y a la desconexión. Los trabajadores tienen derecho a la intimidad en el uso de los dispositivos digitales puestos a su disposición por el empleador, a la desconexión digital y a la intimidad frente al uso de dispositivos de videovigilancia y geolocalización en los términos establecidos en la legislación vigente en materia de protección de datos personales y garantía de los derechos digitales.

• **Artículo 87 de la LOPDGDD 3/2018. Derecho a la intimidad y uso de dispositivos digitales en el ámbito laboral:** Los trabajadores y los empleados públicos tendrán derecho a la protección de su intimidad en el uso de los dispositivos digitales puestos a su disposición por su empleador. El empleador podrá acceder a los contenidos derivados del uso de medios digitales facilitados a los trabajadores a los solos efectos de controlar el cumplimiento de las obligaciones laborales o estatutarias y de garantizar la integridad de dichos dispositivos.

• Los empleadores deberán establecer criterios de utilización de los dispositivos digitales respetando en todo caso los estándares mínimos de protección de su intimidad de acuerdo con los usos sociales y los derechos reconocidos constitucional y legalmente. El acceso por el empleador al contenido de dispositivos digitales respecto de los que haya admitido su uso con fines privados requerirá que se especifiquen de modo preciso los usos autorizados y se establezcan garantías para preservar la intimidad de los trabajadores, tales como, en su caso, la determinación de los períodos en que los dispositivos podrán utilizarse para fines privados.

• Los trabajadores deberán ser informados de los criterios de utilización a los que se refiere este apartado.

2.5 GARANTÍA DE LOS DERECHOS DIGITALES (LOPDGDD)

• Se introduce en la nueva LOPD, la garantía de los derechos digitales.

- **Artículo 88.3 de la LOPDGDD 3/2018 dispone:**
- “El empleador, previa audiencia de los representantes de los trabajadores, **elaborará una política interna** dirigida a trabajadores, incluidos los que ocupen puestos directivos, en la que definirán las modalidades de ejercicio del derecho a la desconexión y las acciones de formación y de sensibilización del personal sobre un uso razonable de las herramientas tecnológicas que evite el riesgo de fatiga informática. En particular, se preservará el derecho a la desconexión digital en los supuestos de realización total o parcial del trabajo a distancia, así como en el domicilio del empleado vinculado al uso con fines laborales de herramientas tecnológicas”.
- **Derecho a la intimidad ante la utilización de sistemas de geolocalización en el ámbito laboral (Artículo 90, LOPDGDD)**
- Los empleadores podrán tratar los datos obtenidos a través de sistemas de geolocalización para el ejercicio de las funciones de control de los trabajadores o los empleados públicos previstas, respectivamente, en el artículo 20.3 del Estatuto de los Trabajadores y en la legislación de función pública, siempre que estas funciones se ejerzan dentro de su marco legal y con los límites inherentes al mismo. Con carácter previo, los empleadores habrán de informar de forma expresa, clara e inequívoca a los trabajadores y, en su caso, a sus representantes, acerca de la existencia y características de estos dispositivos.



PREGUNTAS





GRACIAS POR SU ATENCIÓN